

Aula 2 (Módulo 12) — Análise Prática: IP, Domínio, URL, Hash e Arquivo

Fechando o módulo com o lado prático: o que fazer, passo a passo, quando você tem um indicador extraído (Módulo 06) e precisa decidir se ele é malicioso.

1. Analisando um IP

Perguntas a responder, nessa ordem:

1. **É privado ou público?** (Módulo 03, Aula 1) — se privado, é provavelmente sua própria infraestrutura, não um indicador externo.
2. **A quem pertence?** Uma consulta **WHOIS** revela o dono registrado do bloco de IP (uma empresa de hospedagem? um provedor residencial? um bloco associado a um país específico?).
3. **Tem reputação ruim conhecida?** Plataformas como **AbuseIPDB**, **VirusTotal** e feeds comerciais de Threat Intel agregam relatos de abuso associados àquele IP.
4. **Que serviços estão expostos nele?** Ferramentas de varredura passiva (como o **Shodan**, que indexa continuamente dispositivos expostos na internet) podem revelar se aquele IP hospeda algo consistente com infraestrutura de ataque (ex.: um painel de C2 conhecido).

```
whois 203.0.113.45
dig -x 203.0.113.45 # PTR/reverse DNS — para qual domínio esse IP aponta?
```

Cuidado com falso senso de segurança: um IP "limpo" (sem reputação ruim registrada) não prova inocência — só significa que **ninguém reportou** aquele IP ainda. Infraestrutura nova de ataque começa sempre "limpa".

2. Analisando um domínio

Além do WHOIS (agora do domínio, revelando data de registro, registrar usado), pontos específicos de domínio:

- **Idade do domínio:** domínios registrados **há poucos dias/semanas** são desproporcionalmente mais associados a campanhas maliciosas (infraestrutura descartável) — não é prova definitiva, mas é um sinal relevante.
- **Histórico de resolução DNS** (*passive DNS*): para quais IPs esse domínio já apontou ao longo do tempo? Domínios que mudam de IP com frequência incomum, ou que compartilham infraestrutura com domínios já conhecidos como maliciosos, são mais suspeitos.
- **Typosquatting** (Módulo 03, Aula 4): o domínio se parece propositalmente com uma marca conhecida?

```
whois exemplo-suspeito.com
dig exemplo-suspeito.com ANY
```

3. Analisando uma URL

Uma URL completa (não só o domínio) adiciona: o **caminho** (path), que às vezes revela a ferramenta usada pelo atacante (ex.: caminhos padrão de kits de phishing conhecidos), e **parâmetros** na query string, que podem conter dados codificados (lembra do Base64 do Módulo 02, Aula 2?).

Cuidado: nunca **abra** uma URL suspeita diretamente no seu navegador comum. Use um ambiente isolado — um **sandbox online** (serviços que abrem a URL/arquivo em um ambiente controlado e mostram o comportamento resultante, sem risco para sua máquina) ou uma VM de laboratório isolada (Módulo 00, Aula 3), sem rede de produção acessível.

4. Analisando um hash

Já sabemos calcular hash (Módulo 06, `hash-checker`). O próximo passo é **consultar** se aquele hash já é conhecido:

- **VirusTotal:** agrega o resultado de **dezenas** de motores de antivírus diferentes analisando o mesmo arquivo/hash — em vez de confiar em um único antivírus, você vê o consenso (ou divergência) entre muitos.
- **MalwareBazaar** (abuse.ch): repositório comunitário de amostras de malware, com hashes, tags de família e regras YARA associadas.

Por que importa combinar múltiplas fontes: nenhum motor de antivírus/detecção é perfeito — um hash sem detecção em uma ferramenta específica não significa que é seguro; e mesmo entre dezenas de motores, "0 detecções" em um arquivo **muito novo** (poucas horas de existência) é comum simplesmente porque as bases ainda não foram atualizadas — de novo, "limpo" não é o mesmo que "seguro".

5. Analisando um arquivo (visão geral — aprofundamos no Módulo 20)

Antes de rodar/abrir qualquer arquivo suspeito:

1. **Hash primeiro** (não-destrutivo, rápido, consulta imediata).
2. **Metadados:** tipo real do arquivo (lembra do comando `file` do Módulo 01, Aula 1 — um `.pdf` que na verdade é um executável renomeado é detectado assim), tamanho, data de criação.
3. **Análise estática básica:** strings legíveis dentro do arquivo (comando `strings` no Linux) às vezes revelam URLs, mensagens de erro, ou nomes de função reveladores, **sem executar** o arquivo.
4. Só depois disso, se necessário, **análise dinâmica** (executar em ambiente controlado/sandbox) — tópico central do Módulo 20.

6. Analisando comportamento (revisão)

"Comportamento" aqui remete direto ao que já vimos no Módulo 10 (EDR) e na Aula 1 deste módulo (IOA): não é uma ferramenta nova, é reaplicar o raciocínio de process tree + command line + arquivo + registry + rede, agora **enriquecido** com o contexto de reputação externa que acabamos de aprender a consultar.

7. Conectando tudo — um fluxo de análise completo

```
IOC extraído (Módulo 06) → hash/IP/domínio/URL
↓
Consulta de reputação (VirusTotal, AbuseIPDB, WHOIS, passive DNS)
↓
Se malicioso conhecido → confirma TP imediatamente, prioriza
Se desconhecido/"limpo" → NÃO descarta – analisa comportamento
  (IOA/TTP, Módulo 10) antes de decidir
↓
Documenta a decisão no case (Módulo 08, Aula 2), citando as fontes
consultadas
```

8. Exercício prático

Usando o `ioc-extractor` do Módulo 06 e o relatório de exemplo incluído (`src/ioc-extractor/exemplo_relatorio.txt`):

1. Extraia os IOCs.
2. Para cada domínio extraído, pesquise manualmente o WHOIS (pode ser pelo terminal com `whois`, se disponível, ou por um site de consulta WHOIS).
3. Anote: a idade aproximada do domínio parece consistente com infraestrutura recém-criada para um ataque, ou parece um domínio estabelecido há anos?

(Lembre-se: os domínios do exemplo são fictícios — o exercício é praticar o **processo** de consulta, não encontrar resultados reais para eles.)

9. Recapitulando o Módulo 12

- Análise de IP: privado/público, WHOIS, reputação, serviços expostos — "limpo" não prova inocência, só ausência de relato.
- Análise de domínio: idade do registro, histórico de DNS (passive DNS), typosquatting.
- Nunca abra URL/arquivo suspeito diretamente — use sandbox/VM isolada.
- Hash: consulte múltiplas fontes (VirusTotal, MalwareBazaar); "0 detecções" pode só significar "muito novo", não "seguro".
- Comportamento (IOA) continua sendo a análise mais resistente, mesmo quando os IOCs específicos são desconhecidos.

Módulo 12 concluído. 🎉

Próximo módulo

Módulo 13 — MITRE ATT&CK: formalizamos de vez o vocabulário de táticas e técnicas que já usamos informalmente em quase todo módulo até aqui — a referência mais usada da indústria para descrever comportamento de atacante.

Fontes recomendadas

- **VirusTotal — documentação oficial:** referência de como interpretar resultados de múltiplos motores de antivírus. <https://docs.virustotal.com/>
- **abuse.ch — MalwareBazaar:** repositório comunitário oficial do projeto, referência amplamente usada na indústria. <https://bazaar.abuse.ch/>
- **AbuseIPDB — documentação oficial:** referência de consulta de reputação de IP. <https://www.abuseipdb.com/>